Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Team ID : SWTID-2026-8309

List of Teammates :

S.no	Name	Collage	Contact
01	Narmatha S	Shri Nehru Maha Vidyalaya College Of Arts and Science	narmathanarmu78@gmail.com
02	Sathya A	Shri Nehru Maha Vidyalaya College Of Arts and Science	sathyasathyashivam@gmail.com
03	Santhosh M S	Shri Nehru Maha Vidyalaya College Of Arts and Science	amanickamamanickam33@gmail.com
04	Sabari P	Shri Nehru Maha Vidyalaya College Of Arts and Science	ssabari8467@gmail.com

Introduction :

In modern organizations, protecting sensitive data and applications has become a critical challenge due to the rapid growth of digital transformation and remote working environments. Traditional network security models often rely on perimeter-based protection, where users inside the network are trusted by default. However, this approach can expose systems to significant risks if unauthorized users gain access to internal resources. To overcome these challenges, modern security strategies focus on implementing stronger access control mechanisms that ensure only authorized users can access specific applications and data. One of the key principles in modern cybersecurity is the concept of least-privilege access.

The principle of least privilege is a security concept that ensures users, applications, and systems are given only the minimum level of access necessary to perform their tasks. By limiting unnecessary permissions, organizations can significantly reduce the chances of accidental misuse or malicious attacks. When users have access only to the resources required for their work, the potential damage caused by security breaches can be minimized. This principle is widely used in enterprise security architectures to strengthen protection against internal and external threats.

Identity-aware access control is another important approach in modern security systems. Instead of granting access based solely on network location, identity-aware systems verify the identity of the user before allowing access to specific applications or services. This method ensures that only authenticated and authorized users can access organizational resources, regardless of where they are connecting from. Identity-based policies provide better visibility and control over user activity, helping organizations maintain stronger security and compliance standards.

Application-specific access policies further enhance security by allowing administrators to control which users or groups can access particular applications. This means that users are not given access to the entire network but only to the specific applications they need. Such policies help reduce the attack surface and improve overall system security. By combining identity verification with application-specific policies, organizations can create a more secure and flexible access management system.

One of the technologies that enables this modern approach to secure access is Zscaler Private Access, developed by Zscaler. Zscaler Private Access provides a cloud-based zero trust network access solution that allows organizations to securely connect users to internal applications without exposing the network to the internet. It enforces least-privilege access by verifying user identity and applying application-specific policies before granting access. By implementing ZPA, organizations can improve security, support remote work, and ensure that sensitive applications remain protected from unauthorized access.

Abstract :

In today's digital environment, organizations rely heavily on secure access to internal applications and data. Traditional network security models often provide broad access to users once they are inside the network, which increases the risk of unauthorized access and cyberattacks. To overcome these challenges, modern security frameworks focus on implementing strict access control mechanisms that ensure users can only access the resources necessary for their work. The concept of least-privilege access plays a vital role in strengthening organizational security by limiting unnecessary permissions.

The principle of least privilege ensures that users, applications, and systems are granted only the minimum level of access required to perform their tasks. By restricting excessive permissions, organizations can reduce security risks such as insider threats, accidental data exposure, and unauthorized system usage. This approach also helps organizations maintain better control over sensitive data and critical applications, thereby improving the overall security posture of the network infrastructure.

Identity-aware access control further enhances security by verifying the identity of users before granting them access to specific resources. Instead of relying solely on network location, identity-based systems evaluate user credentials, roles, and authentication methods to determine whether access should be granted. This method ensures that only authenticated and authorized users can access enterprise applications, regardless of their location or device.

To implement this modern security approach, technologies like Zscaler Private Access, developed by Zscaler, provide a cloud-based solution that securely connects users to internal applications without exposing the network. ZPA enforces application-specific access policies and follows a zero-trust security model, ensuring that every access request is verified before permission is granted. By using this approach, organizations can achieve secure remote access, protect sensitive resources, and effectively enforce least-privilege access across their network environment.

Use Case Scenarios :

Scenario 1: Least Privilege Access Control

Least privilege access control is a security principle that ensures users and systems are granted only the minimum permissions required to perform their tasks. This approach reduces the risk of unauthorized actions, accidental data exposure, and internal misuse of sensitive information. By limiting user privileges, organizations can protect critical applications and prevent attackers from gaining excessive control over systems.

In modern enterprise environments, least privilege access is implemented using identity-based authentication and policy enforcement mechanisms. These policies evaluate user identity, role, and device security before granting access to a specific application or

resource. This ensures that users only interact with the systems necessary for their responsibilities while keeping other resources hidden and protected.

Organizations that implement least privilege access control benefit from improved security posture, reduced attack surface, and better compliance with industry security standards.

Output:

- User authenticated and authorized based on identity and role
- Access granted only to the required application or service
- Other internal systems and network segments remain inaccessible

---

Scenario 2: Identity-Aware Authentication

Identity-aware authentication is a modern security approach that verifies the identity of users before granting access to enterprise resources. Unlike traditional security models that rely only on network location, identity-aware systems evaluate user credentials, roles, and authentication factors. This method ensures that access decisions are made based on who the user is rather than where they are connecting from.

Identity-based authentication systems often incorporate multiple verification methods such as passwords, multi-factor authentication, device validation, and user behavior analysis. These mechanisms strengthen the authentication process and help organizations prevent unauthorized access attempts. By verifying identity before granting access, organizations can maintain stronger control over their applications and sensitive data.

This security model is widely used in cloud environments and remote work infrastructures where users access applications from different locations and devices.

Output:

- Strong authentication performed before granting access
- Access permissions determined based on verified user identity
- Unauthorized users prevented from accessing protected resources

---

Scenario 3: Application-Specific Access Policies

Application-specific access policies allow organizations to control which users or groups can access particular applications within the network. Instead of granting broad access to entire network segments, administrators define policies that restrict users to only the applications required for their work. This approach significantly improves security by reducing unnecessary exposure of internal resources.

These policies are enforced using centralized security management systems that evaluate user identity, device security status, and organizational roles. When a user attempts to access an application, the system checks whether the request satisfies the defined access rules. If the request meets the policy conditions, access is granted; otherwise, the connection is denied.

Application-specific access control helps organizations maintain better security visibility, protect sensitive applications, and prevent unauthorized exploration of internal systems.

Output:

- Access restricted to specific authorized applications
- Users prevented from viewing or accessing unrelated systems
- Network attack surface significantly reduced

Scenario 4: Secure Remote Access Management

Secure remote access management enables employees, administrators, and partners to safely connect to internal applications from remote locations. With the increase in remote work and cloud-based infrastructure, organizations must ensure that external connections are secure and properly authenticated. Traditional VPN-based systems often expose large portions of the network, which can increase security risks.

Modern remote access solutions use identity verification, device security checks, and encrypted connections to ensure that only trusted users can access internal applications. These systems provide secure application-level connectivity rather than full network access. As a result, users can perform their work tasks without exposing the organization’s internal network to potential threats.

Secure remote access management improves productivity while maintaining strict security policies and protecting sensitive business resources.

Output:

- Encrypted connection established for remote users
- Access limited to approved applications only
- Internal network infrastructure remains hidden and protected

---

Scenario 5: Zero Trust Security Implementation

Zero Trust security is a cybersecurity model that operates on the principle of "never trust, always verify." In this approach, no user or device is automatically trusted, even if

they are inside the organizational network. Every access request must be authenticated, authorized, and validated before access to any resource is granted.

Zero Trust architecture continuously evaluates factors such as user identity, device posture, location, and security policies before establishing a connection. This approach ensures that only legitimate users can access sensitive applications and prevents attackers from moving freely within the network. By implementing Zero Trust principles, organizations can significantly strengthen their security defenses against modern cyber threats.

Zero Trust security frameworks are widely adopted in modern enterprises to protect cloud environments, internal applications, and critical data assets.

Output:

- Continuous verification of user identity and device security
- Access granted only after policy validation
- Unauthorized access attempts automatically blocked

Stage – 1

Tittle:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview:

The main goal of ZPA is to enforce least-privilege access. Least-privilege access means users are given only the minimum permissions required to access specific applications needed for their work. Instead of allowing full network access, ZPA provides application-specific access based on identity, device posture, and policies.

ZPA works by connecting users directly to applications through secure micro-tunnels. When a user tries to access an application, ZPA checks the user's identity, authentication status, device security posture, and access policy rules. If the user satisfies the policy conditions, ZPA allows access only to that particular application and blocks access to other resources. This helps prevent unauthorized access and reduces the attack surface.

Organizations create identity-aware policies in ZPA using identity providers such as Microsoft Azure Active Directory or Okta. These policies define which user or user group can access which application. For example, HR employees can access HR applications, while developers can access development tools. This ensures strict control over application access.

By using ZPA, companies can replace traditional VPNs, improve security, protect internal applications, and provide safe remote access for employees. It also ensures scalability, secure connectivity, and compliance with modern cybersecurity standards.

List of Vulnerability:

S.no	Category	Vulnerability Name	CWE No.
01	Broken access control	Windows hard link	CWE -65
02	Security Misconfiguration	Configuration	CWE -16
03	Software Supply Chain Failures	Use of Obsolete function	CWE -447
04	Cryptographic Failures	Insufficient entropy	CWE -331
05	Injection	Process Control	CWE -114
06	Insecure Design	Excessive Attack Surface	CWE -1125
07	Authentication failures	Weak Password Requirements	CWE -521
08	Software or data integrity failures	Untrusted search path	CWE -426
09	Security logging and alerting failures	Insufficient logging	CWE -778
10	Mishandling of exceptional conditions	Divide by zero	CWE -369

Report:

1. Vulnerability name: Windows hard link

   CWE:65

   OWASP category: Broken access control

   Description: A Windows Hard Link vulnerability occurs when a system allows the creation of hard links that point to sensitive files without proper access validation. In the Windows file system, a hard link is a reference that allows multiple filenames to point to the same physical file on disk.

   Business Impact: If exploited, the Windows Hard Link vulnerability can allow attackers to manipulate or overwrite critical system files. This may result in privilege escalation, unauthorized modification of system configurations, or disruption of application functionality. Attackers could gain higher-level access to the system, compromise sensitive data, or cause system instability. In enterprise environments, such vulnerabilities may also lead to security breaches, service interruptions, and loss of trust in the affected system.

Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-65: Windows Hard Link (4.19.1)

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-65: Windows Hard Link

Weakness ID: 65
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product, when opening a file or directory, does not sufficiently handle when the name is associated with a hard link to a target that is outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

Extended Description

Failure for a system to check for hard links can result in vulnerability to different types of attacks. For example, an attacker can escalate their privileges if a file used by a privileged program is replaced with a hard link to a sensitive file (e.g. AUTOEXEC.BAT). When the process opens the file, the attacker can assume the privileges of that process, or prevent the program from accurately processing data.

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	**Scope: Confidentiality, Integrity**

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	**Strategy:** ***Separation of Privilege***

Recommendation:

- Apply proper file permission and access control to restrict unauthorized users.
- Validate file paths and prevent applications from following untrusted hard links.
- Keep the Windows system updated with latest security patches to prevent exploitation.

2. Vulnerability name: Configuration

   CWE:16

   OWASP category: Security Misconfiguration

   Description: Configuration vulnerability occurs when a system or application is not properly configured. This may include default settings, weak permissions, unnecessary services, or improper security controls.

   Business Impact: Improper configuration can allow unauthorized users to access sensitive information or system resources. It may also expose the system to cyber attacks, data breaches, and service disruptions. This can lead to loss of important data, financial loss, and damage to the organization's reputation.

CWE CATEGORY: Configuration

Category ID: 16
Vulnerability Mapping: PROHIBITED

Summary

Weaknesses in this category are typically introduced during the configuration of the software.

Membership

Nature	Type	ID	Name
MemberOf	V	635	Weaknesses Originally Used by NVD from 2008 to 2016
MemberOf	C	933	OWASP Top Ten 2013 Category A5 - Security Misconfiguration
MemberOf	C	1032	OWASP Top Ten 2017 Category A6 - Security Misconfiguration
MemberOf	C	1349	OWASP Top Ten 2021 Category A05:2021 - Security Misconfiguration
MemberOf	C	1437	OWASP Top Ten 2025 Category A02:2025 - Security Misconfiguration

Vulnerability Mapping Notes

Usage: PROHIBITED *(this CWE ID must not be used to map to real-world vulnerabilities)*

Reason: Category

Rationale:
This entry is a Category. Using categories for mapping has been discouraged since 2019. Categories are informal organizational groupings of weaknesses that can help CWE users with data aggregation, navigation, and browsing. However, they are not weaknesses in themselves [REF-1287]. This CWE entry may have become widely-used because of NIST's usage in NVD from 2008 to 2016 (see CWE-635 view, updated to the CWE-1003 view in 2016). Mapping is also Prohibited because this entry's status is Obsolete.

Recommendation:

- Apply secure configuration settings for systems and applications.
- Disable default accounts and unnecessary services.
- Regularly review system configurations and apply security updates.

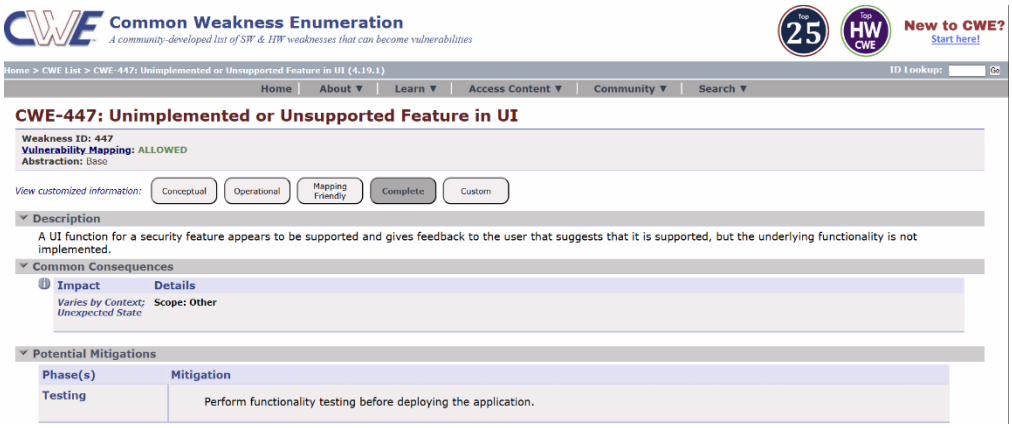
3. Vulnerability name: Use of Obsolete function

   CWE:447

   OWASP category: Software Supply Chain Failures

   Description: A Use of Obsolete Function vulnerability occurs when a system or application uses outdated or deprecated functions that are no longer recommended. These functions may contain security weaknesses or may not follow current security standards.

   Business Impact: Using obsolete functions can expose the system to security vulnerabilities and potential attacks. It may lead to data breaches, unauthorized access, or system malfunction. This can result in loss of sensitive information, operational issues, and damage to the organization's reputation.



Recommendation:

- Replace obsolete or deprecated functions with secure and updated alternatives.
- Regularly update libraries and software components used in the application.
- Follow secure coding standards and best practices during development.

4. Vulnerability name: Insufficient entropy

   CWE:331

OWASP category: Cryptographic Failures

Description: Insufficient entropy vulnerability occurs when a system uses weak or predictable random values while generating security-sensitive data such as session IDs, tokens, passwords, or encryption keys.

Business Impact: Weak randomness can allow attackers to predict authentication tokens or session identifiers, leading to unauthorized access to user accounts or systems. This may result in data breaches, account compromise, and loss of sensitive business information, which can affect the organization's security and reputation.

CWE-331: Insufficient Entropy

Weakness ID: 331
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses an algorithm or scheme that produces insufficient entropy, leaving patterns or clusters of values that are more likely to occur than others.

Common Consequences

Impact	Details
Bypass Protection Mechanism; Other	**Scope: Access Control, Other** An attacker could guess the random numbers generated and could gain unauthorized access to a system if the random numbers are used for authentication and authorization.

Potential Mitigations

Phase(s)	Mitigation
Implementation	Determine the necessary entropy to adequately provide for randomness and predictability. This can be achieved by increasing the number of bits of objects such as keys and seeds.

Recommendation:

- Use strong cryptographic random number generators for generating tokens and keys.
- Avoid using predictable values such as timestamps or simple algorithms for security purposes.
- Implement secure libraries and updated cryptographic standards for randomness generation.

5. Vulnerability Name: Process Control

   CWE:114

   OWASP category: Injection

   Description: Process Control vulnerability occurs when an application does not properly control or restrict the processes it executes. If input validation or permission checks are missing, attackers may manipulate the process execution to run unauthorized commands or programs.

Business Impact: Improper process control can allow attackers to execute unauthorized commands on the system. This may result in system compromise, data manipulation, or service disruption. It can also affect the stability and security of the organization's applications and infrastructure.

CWE-114: Process Control

Weakness ID: 114
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Executing commands or loading libraries from an untrusted source or in an untrusted environment can cause an application to execute malicious commands (and payloads) on behalf of an attacker.

Extended Description

Process control vulnerabilities take two forms:

- An attacker can change the command that the program executes: the attacker explicitly controls what the command is.
- An attacker can change the environment in which the command executes: the attacker implicitly controls what the command means.

Process control vulnerabilities of the first type occur when either data enters the application from an untrusted source and the data is used as part of a string representing a command that is executed by the application. By executing the command, the application gives an attacker a privilege or capability that the attacker would not otherwise have.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	**Scope: Confidentiality, Integrity, Availability**

Recommendation:

- Implement strict access control and validation before executing any process.
- Restrict applications to run only authorized commands or programs.
- Regularly monitor and audit system processes to detect suspicious activities.

6. Vulnerability name: Excessive Attack Surface

   CWE:1125

   OWASP category: Insecure Design

   Description: Excessive attack surface vulnerability occurs when a system exposes more services, ports, applications, or functionalities than necessary.

   Business Impact: An excessive attack surface increases the chances of security breaches and unauthorized access. Attackers may exploit unused services or open ports to compromise the system, steal sensitive information, or disrupt operations.

CWE-1125: Excessive Attack Surface

Weakness ID: 1125
Vulnerability Mapping: PROHIBITED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product has an attack surface whose quantitative measurement exceeds a desirable maximum.

Extended Description

Originating from software security, an "attack surface" measure typically reflects the number of input points and output points that can be utilized by an untrusted party, i.e. a potential attacker. A larger attack surface provides more places to attack, and more opportunities for developers to introduce weaknesses. In some cases, this measure may reflect other aspects of quality besides security; e.g., a product with many inputs and outputs may require a large number of tests in order to improve code coverage.

Common Consequences

Impact	Details
Varies by Context	**Scope: Other**

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf		1120	Excessive Code Complexity

Recommendation:

- Disable unused services, ports, and applications that are not required.
- Implement strong access control and network security policies.
- Regularly review and minimize exposed system components to reduce the attack surface.

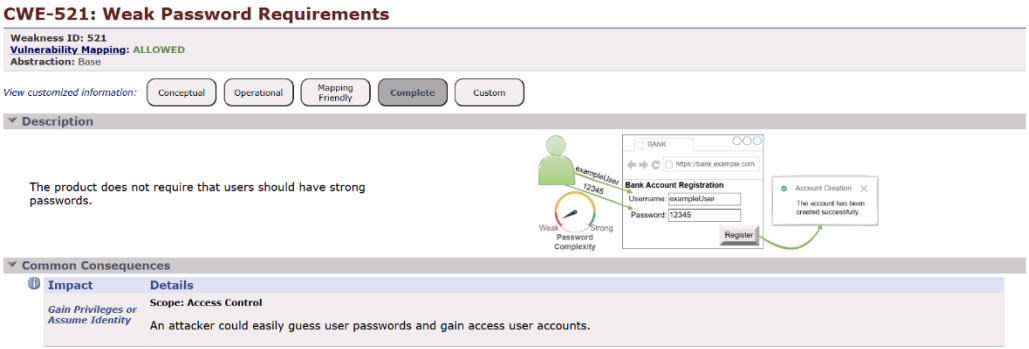
7. Vulnerability name: Weak password requirements

   CWE:521

   OWASP category: Authentication failures

   Description: Weak password requirements vulnerability occurs when a system allows users to create simple or easily guessable passwords.

   Business Impact: Weak passwords can allow attackers to gain unauthorized access to user accounts or system resources. This may lead to data breaches, misuse of sensitive information, and compromise of the system.



Recommendation:

- Enforce strong password policies such as minimum length and complexity.
- Require the use of uppercase, lowercase, numbers, and special characters in passwords.
- Implement multi-factor authentication (MFA) to provide an additional layer of security.

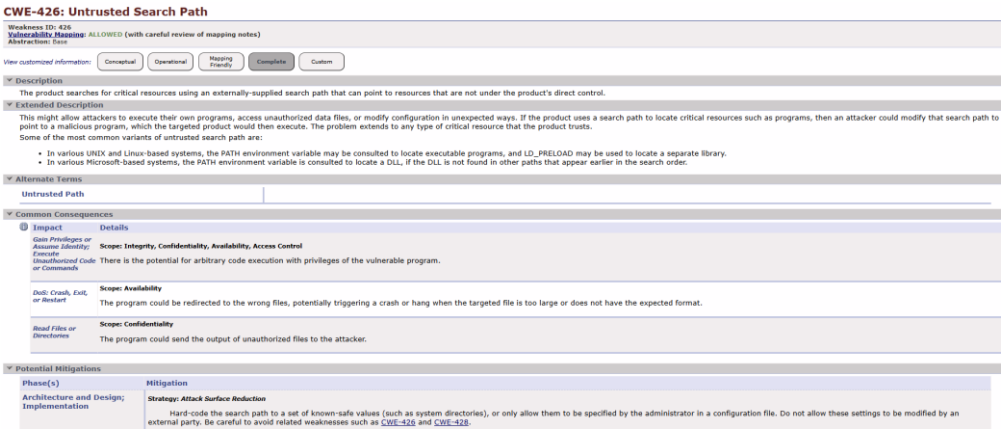
8. Vulnerability name: Untrusted search path

   CWE:426

OWASP category: Software or data integrity failures

Description: An Untrusted Search Path vulnerability occurs when an application loads files or executable programs from directories that are not properly controlled or trusted.

Business Impact: This vulnerability can allow attackers to execute malicious code on the system. It may lead to unauthorized access, system compromise, or data manipulation.



CWE-426: Untrusted Search Path

Weakness ID: 426
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product searches for critical resources using an externally-supplied search path that can point to resources that are not under the product's direct control.

Extended Description

This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts.
Some of the most common variants of untrusted search path are:

- In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable programs, and LD_PRELOAD may be used to locate a separate library.
- In various Microsoft-based systems, the PATH environment variable is consulted to locate a DLL, if the DLL is not found in other paths that appear earlier in the search order.

Alternate Terms

Untrusted Path

Common Consequences

Impact	Details
Gain Privileges or Assume Identity; Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability, Access Control** There is the potential for arbitrary code execution with privileges of the vulnerable program.
DoS: Crash, Exit, or Restart	**Scope: Availability** The program could be redirected to the wrong files, potentially triggering a crash or hang when the targeted file is too large or does not have the expected format.
Read Files or Directories	**Scope: Confidentiality** The program could send the output of unauthorized files to the attacker.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design; Implementation	**Strategy: *Attack Surface Reduction*** Hard-code the search path to a set of known-safe values (such as system directories), or only allow them to be specified by the administrator in a configuration file. Do not allow these settings to be modified by an external party. Be careful to avoid related weaknesses such as CWE-426 and CWE-428.

Recommendation:

- Ensure applications use trusted and secure directories when loading files or executables.
- Avoid searching for executable files in untrusted or user-writable locations.
- Implement proper path validation and access control to prevent malicious file execution.

9. Vulnerability name: Insufficient logging

   CWE:778

   OWASP category: Security logging and alerting failures

   Description: Insufficient logging vulnerability occurs when a system or application does not properly record important security events and activities.

   Business Impact: When logging is insufficient, organizations may not be able to detect or investigate security incidents effectively. This can allow attackers to remain undetected for a long time, potentially leading to data breaches, system compromise, or operational disruptions.

CWE-778: Insufficient Logging

Weakness ID: 778
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it.

Extended Description

When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.

As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

Common Consequences

Impact	Details
Hide Activities	**Scope: Non-Repudiation** If security critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible.

Recommendation:

- Enable detailed logging for important system and security events.
- Regularly monitor and review log files to detect suspicious activities.
- Implement centralized logging and log management systems for better security monitoring.

10. Vulnerability name: Divide by zero

    CWE:369

    OWASP category: Mishandling of exceptional conditions

    Description: A Divide by Zero vulnerability occurs when a program attempts to divide a number by zero without proper validation.

    Business Impact: If exploited, this vulnerability can cause application errors or system crashes, leading to service disruption. It may affect the availability and reliability of the application, potentially interrupting business operations and degrading user experience.

CWE-369: Divide By Zero

Weakness ID: 369
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product divides a value by zero.

Extended Description

This weakness typically occurs when an unexpected value is provided to the product, or if an error occurs that is not properly detected. It frequently occurs in calculations involving physical dimensions such as size, length, width, and height.

Common Consequences

Impact	Details
DoS: Crash, Exit, or Restart	**Scope: Availability** A Divide by Zero results in a crash.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	B	682	Incorrect Calculation

Relevant to the view "Software Development" (View-699)

Nature	Type	ID	Name
MemberOf	C	189	Numeric Errors

Relevant to the view "Weaknesses for Simplified Mapping of Published Vulnerabilities" (View-1003)

Nature	Type	ID	Name
ChildOf	B	682	Incorrect Calculation

Recommendation:

- Validate input values to ensure the denominator is never zero before performing division.

- Implement error handling and exception handling for arithmetic operations.

Stage – 2

Overview of a Nessus Scan

1. Preparation: Define Objectives

Before performing a scan, it is important to clearly determine the goal of the assessment. This includes identifying which systems, applications, or network segments need to be evaluated and what type of vulnerabilities the organization wants to detect.

2. System Access

Proper authorization must be obtained prior to scanning. Security administrators should ensure they have the necessary permissions and credentials to access the target machines and networks to avoid operational or legal issues.

3. Configuration: Set Up Scan Policy

A scan policy must be configured to control how the scan will operate. This configuration defines the vulnerability checks, scanning techniques, authentication options, and other settings that determine how the tool will analyze the systems.

4. Define Target Assets

At this stage, the specific systems or network resources that need to be scanned are selected. These targets may include individual IP addresses, hostnames, or entire network ranges within the organization.

5. Scanning: Initiate Scan

Once the scan settings and targets are finalized, the scanning process begins. The **Nessus scanner connects to the designated systems and performs various security tests using its updated vulnerability database.

6. Vulnerability Identification

During the scan, the tool examines systems to locate potential weaknesses such as unpatched software, configuration errors, exposed services, and insecure protocols. Each detected issue is categorized based on its severity level.

7. Reporting

After completing the scan, Nessus generates detailed reports containing information about the vulnerabilities discovered. These reports usually include descriptions of the issues, risk levels, and recommendations for fixing them, and can be exported in different formats.

8. Remediation

Security teams analyze the scan results and prioritize vulnerabilities according to their risk impact. Necessary actions are then taken to resolve the issues, such as applying updates, modifying configurations, or strengthening security controls.

9. Follow-up: Regular Scanning

Organizations typically perform vulnerability scans on a regular basis to continuously monitor their systems. This helps detect newly emerging vulnerabilities and confirm that previously identified issues have been resolved.

10. User Training

IT and security personnel should be trained to properly use Nessus and understand its reports. Proper training ensures that teams can interpret scan results accurately and take appropriate corrective measures.

Understanding Nessus Scanning

1. Vulnerability Assessment

Nessus is designed to evaluate systems for possible security weaknesses. It scans devices and applications to detect issues such as outdated software, weak security settings, and configuration errors that attackers might exploit.

2. Network Scanning

The tool can analyze multiple types of network equipment including servers, routers, switches, and firewalls. It inspects running services, open ports, and active applications to determine if any potential risks exist within the network environment.

3. Plugin Architecture

Nessus operates using a plugin-based system. Each plugin performs a specific security test, and the plugin database is frequently updated to ensure the scanner can detect newly discovered vulnerabilities.

4. Compliance Auditing

Nessus can also evaluate systems against established security standards and regulatory requirements. This helps organizations verify whether their systems comply with frameworks such as PCI DSS or CIS Benchmarks.

5. Customization

The scanning process can be adjusted to match the organization’s requirements. Users are able to configure scan policies, choose specific targets, and define the type of security checks they want the tool to perform.

6. Reporting

Once the scanning process finishes, Nessus creates reports summarizing the vulnerabilities that were found. These reports provide details about the risk level, the affected systems, and suggestions for resolving the issues.

7. Scanning Frequency

To maintain strong security, organizations usually schedule vulnerability scans regularly. Continuous scanning helps detect newly emerging threats and ensures that systems remain protected over time.

8. Integration

Nessus can work together with other security tools and platforms. Integrating it with security management systems allows organizations to automate vulnerability monitoring and improve overall security operations.

9. Licensing

Nessus is available in both free and paid versions. The free edition offers basic scanning capabilities, while commercial versions provide additional features, advanced reporting, and professional support.

10. User-Friendly Interface

The tool provides a web-based interface that simplifies the scanning process. Its dashboard and reporting features make it easier for both experienced security professionals and less experienced IT staff to manage vulnerability scans.

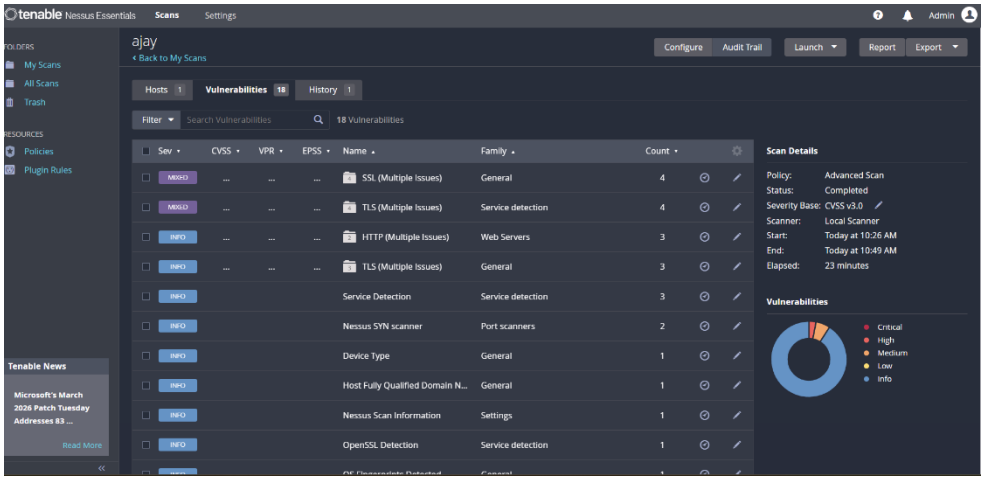
It's important to note that Nessus is a valuable tool for identifying vulnerabilities, but it doesn't fix these vulnerabilities itself. It's up to the organization's IT and security teams to take the necessary steps to remediate the identified issues to enhance their security.

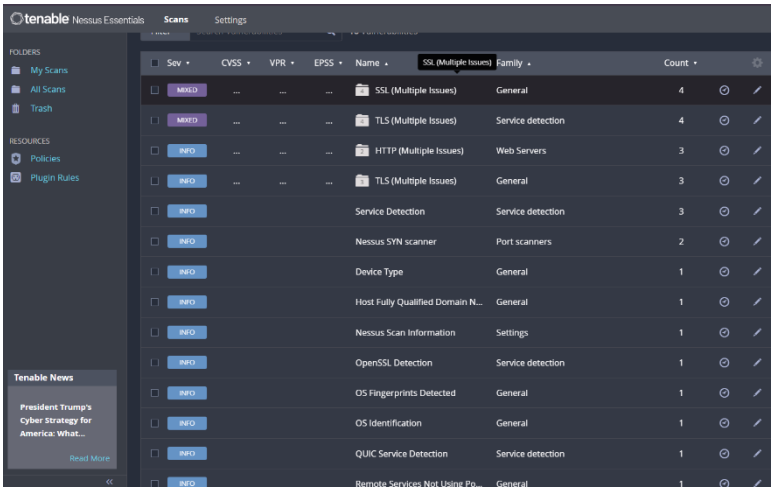
Target Website: https://public-firing-range.appspot.com

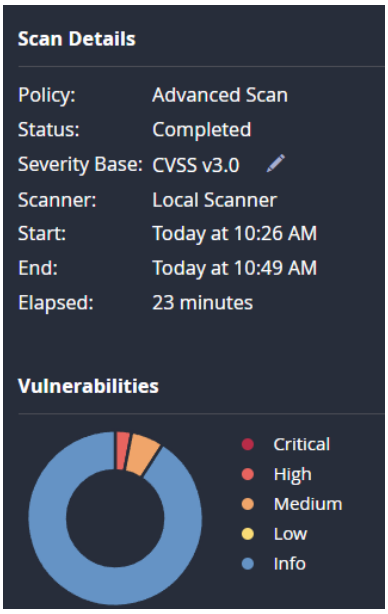
Target IP Address: 142.250.189.212

The scan results are categorized based on severity levels such as Informational, Low, Medium, High, and Critical. These findings help security professionals understand the risks associated with the system and recommend appropriate mitigation measures to improve the overall security posture of the application.

NESSUS SCAN REPORT:







List of Detected Vulnerabilities with Plugin Family, Severity and Plugin ID:

S. No	Vulnerability Name	Severity	Plugins Id
01	Service Detection	Info	22964
02	Nessus SYN scanner	Info	11219
03	Device Type	Info	54615
04	Nessus Scan Information	Info	19506
05	OS Fingerprint Detected	Info	209654
06	OS Identification	Info	11936
07	QUIC Service Detection	Info	206982
08	OpenSSL Detective	Info	50845

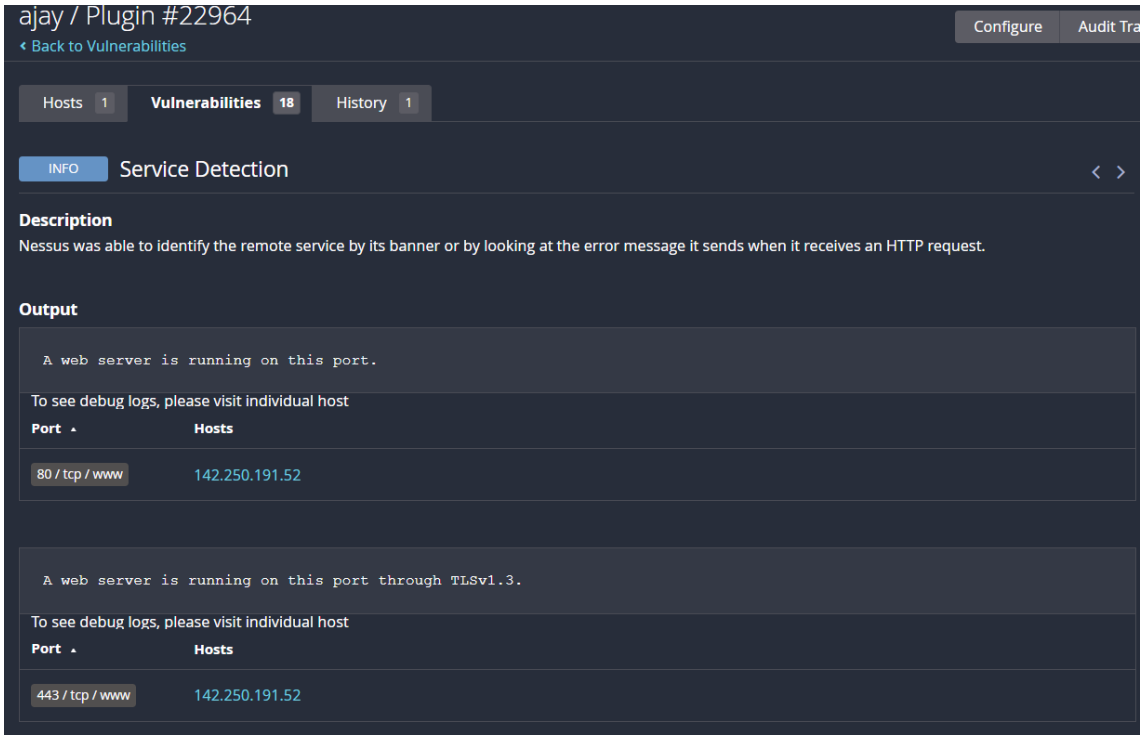
1. Service Detection

Vulnerability Name: Service Detection
Severity: Info
Plugin: 22964
Port: Multiple

Description:
The vulnerability scanner identified active services running on the target system. Service detection allows the scanner to determine which network services are exposed and their corresponding ports.

Solution:
Restrict unnecessary services and ensure that only required services are accessible using identity-aware access controls such as **Zscaler Private Access policies.

Business Impact:
Unnecessary exposed services may increase the attack surface and allow attackers to enumerate system services.



---

2. Nessus SYN Scanner

Vulnerability Name: SYN Scanner Detection
Severity: Info
Plugin: 11219
Port: Multiple

Description:
The SYN scan technique was used by **Nessus** to identify open TCP ports without completing the full TCP handshake.

Solution:
Implement firewall rules and application access policies to limit unauthorized scanning attempts.

Business Impact:
Open ports discovered through SYN scans could reveal potential entry points for attackers.

INFO Nessus SYN scanner

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Output

```
Port 80/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	142.250.191.52

---

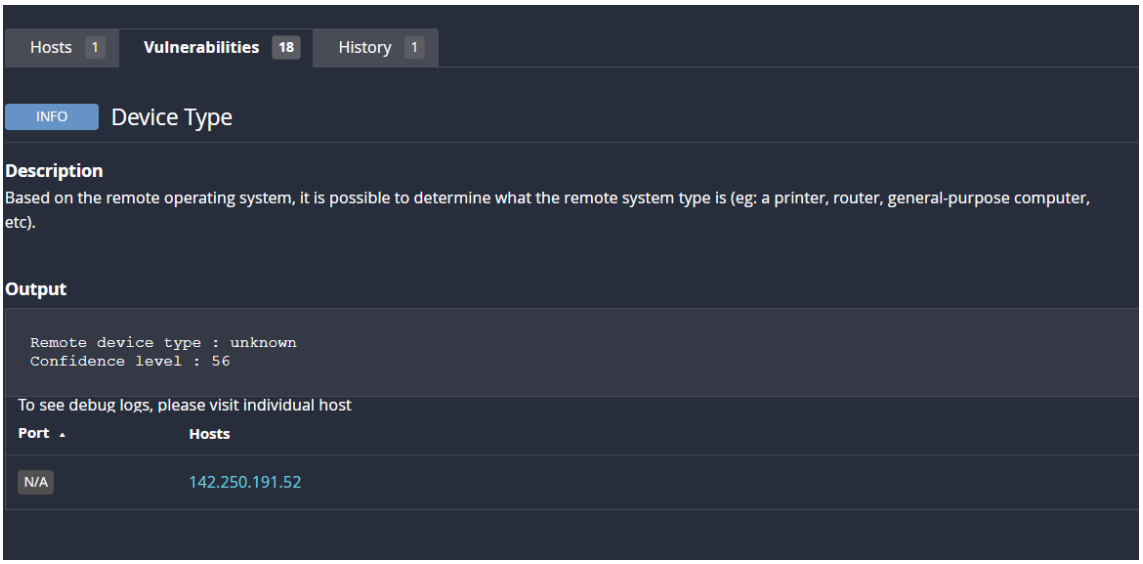
3. Device Type

Vulnerability Name: Device Type Detection
Severity: Info
Plugin: 54615
Port: N/A

Description:
The scanner identified the type of device connected to the network based on responses from the host system.

Solution:
Apply network segmentation and identity-aware access policies to restrict device access.

Business Impact:
Attackers may use device type information to tailor specific attacks.



---

4. Nessus Scan Information

Vulnerability Name: Nessus Scan Information
Severity: Info
Plugin: 19506
Port: N/A

Description:
This plugin provides general information about the scanning process including scan type, duration, and configuration.

Solution:
No direct remediation required.

Business Impact:
Minimal security impact as it only contains scan metadata.

INFO Nessus Scan Information

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Output

```
Information about this scan :

Nessus version : 10.11.3
Nessus build : 20047
Plugin feed version : 202602142328
Scanner edition used : Nessus Home
Scanner OS : WINDOWS
Scanner distribution : win-x86-64
```

---

5. OS Fingerprint Detected

Vulnerability Name: OS Fingerprint Detection
Severity: Info
Plugin: 209654

Description:
The scanner identified the operating system running on the target system.

Solution:
Hide OS details where possible and apply **Zero Trust security principles** using **Zscaler Private Access**.

Business Impact:
OS identification helps attackers exploit OS-specific vulnerabilities.

INFO OS Fingerprints Detected

Description

Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. While the highest-confidence result was reported in plugin 11936, "OS Identification", the complete set of fingerprints detected are reported here.

Output

```
Following OS Fingerprints were found

Remote operating system : SpinStream2
Confidence level : 56
Method : MLSinFP
Type : unknown
Fingerprint : unknown

more...
```

To see debug logs, please visit individual host

---

6. OS Identification

Vulnerability Name: Operating System Identification
Severity: Info
Plugin: 11936

Description:
The scanning tool detected the operating system based on network responses.

Solution:
Use network security controls and limit system information exposure.

Business Impact:
Attackers can exploit OS-specific vulnerabilities.

INFO OS Identification

Description

Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Output

```
Remote operating system : SpinStream2
Confidence level : 56
Method : MLSinFP


The remote host is running SpinStream2
```

To see debug logs, please visit individual host

Port	Hosts
N/A	142.250.191.52

---

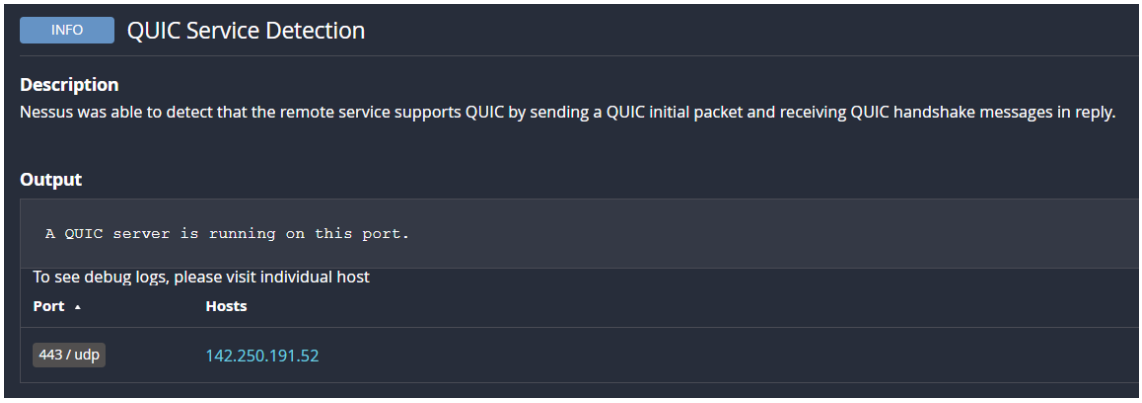
7. QUIC Service Detection

Vulnerability Name: QUIC Service Detection
Severity: Info
Plugin: 206982
Port: 443/UDP

Description:
The scanner detected that the system supports the QUIC protocol used for secure internet communication.

Solution:
Ensure that QUIC services are updated and configured securely.

Business Impact:
Improper configuration may expose communication channels.



---

8. OpenSSL Detection

Vulnerability Name: OpenSSL Detection
Severity: Info
Plugin: 50845
Port: 443

Description:
The scanner detected the presence of **OpenSSL cryptographic libraries used for secure communications.

Solution:
Ensure OpenSSL is updated regularly and patched against known vulnerabilities.

Business Impact:
Outdated OpenSSL versions could expose systems to cryptographic attacks.

INFO

OpenSSL Detection

Description

Based on its response to a TLS request with a specially crafted server name extension, it seems that the remote service is using the OpenSSL library to encrypt traffic.

Note that this plugin can only detect OpenSSL implementations that have enabled support for TLS extensions (RFC 4366).

See Also

https://www.openssl.org/

Output

```
No output recorded.
```

To see debug logs, please visit individual host

Port ▲	Hosts
443 / tcp / www	142.250.191.52

Stage – 3

Tittle:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Zero Trust Network Access (ZTNA)

Zero Trust Network Access is a modern security model that ensures no user or device is automatically trusted. Every access request must be verified before allowing entry to a system or application. Instead of giving users full network access, ZTNA allows them to connect only to specific applications they are authorized to use. This approach improves security by reducing unauthorized access and limiting the risk of cyberattacks within the network.

Zscaler Private Access (ZPA)

Zscaler Private Access is a cloud-based security solution that provides secure remote access to internal applications without exposing the network to the internet. It connects users directly to the applications they need through encrypted connections. ZPA verifies user identity, device security, and access policies before granting permission. This ensures that only authorized users can access specific applications while keeping the internal network hidden.

Principle of Least Privilege

The Principle of Least Privilege means giving users only the minimum level of access required to perform their tasks. In an organization, employees should only access the applications and data necessary for their roles. This reduces the risk of misuse, accidental damage, or cyberattacks. By applying least-privilege access with ZPA, organizations can prevent unauthorized users from accessing sensitive systems.

Identity-Aware Access

Identity-aware access focuses on verifying the identity of the user before granting access to applications. Access decisions are based on factors such as user identity, role, department, and device status. Integration with identity providers like Active Directory helps manage users and groups effectively. This ensures that only authenticated and authorized users can access internal applications.

Application-Specific Access Policies

Application-specific access policies allow administrators to control access at the application level instead of the network level. Policies define which users or groups can access certain applications based on their roles and permissions. This method improves security by restricting unnecessary access and protecting sensitive resources from unauthorized users.

ZPA Architecture and Components

1. Zscaler Cloud

The Zscaler cloud acts as a secure gateway that connects users to internal applications. It manages authentication, policy enforcement, and secure communication between users and applications.

2. App Connector

The App Connector is a lightweight component installed in the organization's data center or cloud environment. It creates a secure outbound connection to the Zscaler cloud and allows access to internal applications without opening inbound firewall ports.

3. ZPA Client Connector

The ZPA Client Connector is software installed on user devices. It authenticates users and establishes a secure connection to the Zscaler cloud so they can safely access authorized applications.

4. Application Segments

Application segments group internal applications based on access requirements. Administrators can define which users are allowed to connect to specific applications through these segments.

Implementation Methodology

Phase 1: Discovery

Identify all internal applications used within the organization and classify them based on business importance and access requirements.

Phase 2: Connector Deployment

Install App Connectors in the data center or cloud environment where the applications are hosted.

Phase 3: Application Configuration

Define application segments and configure the internal application details such as IP addresses and ports.

Phase 4: Policy Creation

Create access policies based on user roles, departments, and security requirements.

Phase 5: Testing and Deployment

Test the configuration with a small group of users and gradually deploy the solution to all employees.

Phase 6: Legacy VPN Removal

Once ZPA is fully implemented, the traditional VPN can be removed to reduce security risks.

Tools and Technologies

- **Zscaler Private Access (ZPA)** – Secure remote access platform
- **Identity Providers** – Active Directory, Okta
- **Endpoint Security Tools** – Microsoft Defender, CrowdStrike
- **SIEM Tools** – Splunk, IBM QRadar
- **Cloud Platforms** – AWS, Azure, Google Cloud

Device Posture Checking

ZPA also checks the security status of the device before granting access. It verifies factors such as antivirus protection, system updates, and device encryption. If the device does not meet the required security standards, access may be limited or blocked.

Incident Response in ZPA

ZPA helps security teams quickly respond to security threats.

1. **Access Revocation** – Immediately block compromised users or devices.
2. **Log Analysis** – Review access logs to identify suspicious activity.
3. **Threat Containment** – Prevent attackers from accessing other systems.
4. **Policy Enforcement** – Update policies to strengthen security.

Understanding ZPA: Key Takeaways

1. **Cloud-Based Security** – ZPA provides secure access to private applications through a cloud platform without requiring traditional VPN infrastructure.

2. **User Identity Focused** – Access decisions are based on the user's identity, role, and authentication instead of relying only on IP addresses.
3. **Application-Level Access** – Users are allowed to connect only to specific applications they are permitted to use, not the entire network.
4. **Improved Security Visibility** – Administrators can monitor user activity and access logs to detect and respond to security threats quickly.
5. **Flexible and Scalable** – ZPA supports remote users and hybrid environments, making it suitable for modern cloud and on-premise infrastructures.

Conclusion:

Stage 1

In conclusion, web application testing plays a vital role in ensuring that modern web systems operate securely, efficiently, and reliably. It involves evaluating different components of an application such as functionality, usability, performance, and security in order to detect and resolve issues before the application is delivered to users. Proper testing helps improve the overall quality of web applications while minimizing potential risks and vulnerabilities. As web technologies continue to grow and become part of everyday life, effective testing practices remain essential for delivering secure and smooth digital experiences to users.

Stage 2

The vulnerability assessment performed using Nessus provided valuable insights into the security condition of the tested website. The analysis identified multiple vulnerabilities and categorized them according to their severity levels, allowing critical risks to be addressed with higher priority. The report also suggested several remediation measures such as applying security patches, improving configurations, and strengthening system defenses. Aligning these solutions with security standards like the OWASP guidelines ensures that the application follows globally recognized security practices. Overall, the assessment highlights the importance of continuous monitoring, periodic updates, and proactive security management to maintain a strong and reliable web security framework.

Stage 3

The deployment of Zscaler Private Access represents an important step toward implementing a modern Zero Trust security model. By shifting from traditional network-based security to an identity-focused approach, organizations can control access more effectively and protect private applications from external exposure. This

approach helps prevent threats such as unauthorized access and lateral movement within networks. Additionally, it improves the user experience by enabling secure and direct access to applications without relying heavily on traditional VPN systems. Overall, adopting Zero Trust architecture strengthens organizational security, simplifies IT management, and prepares businesses for future digital transformation initiatives.

Future Scope

Stage 1: Future Scope of Web Application Testing

The future of web application testing is expected to expand significantly as digital services continue to dominate modern business operations. With organizations relying heavily on web-based platforms, ensuring the reliability, performance, and security of these applications will become increasingly important. Web application testing will evolve to address more complex architectures and user expectations.

Some important aspects that highlight the future scope include:

- **Growing Demand:** As companies continue to digitalize their services, the number of web applications will increase. This will create a greater need for skilled testers who can ensure applications function securely and efficiently.
- **Emerging Technologies:** Technologies such as Artificial Intelligence (AI), Internet of Things (IoT), and blockchain are becoming part of modern web applications. Testing these advanced systems will require new tools, frameworks, and specialized testing strategies.
- **Stronger Focus on Security:** With the rising number of cyberattacks and data breaches, security testing will become a top priority. Testers will need to identify vulnerabilities early and ensure compliance with security standards and regulations.
- **Cross-Platform and Mobile Compatibility:** As users access web applications through different devices such as smartphones, tablets, and desktops, testing must ensure consistent performance across multiple browsers, operating systems, and screen sizes.
- **Performance and Load Testing:** Modern users expect fast and responsive applications. Future testing approaches will emphasize load testing, stress testing, and scalability testing to handle large volumes of traffic.

Stage 2: Future Scope of the Testing Process

The evolution of web application testing will greatly influence how vulnerabilities and system weaknesses are identified. As cyber threats continue to evolve, the testing

process will also adopt more advanced and automated techniques to ensure stronger security and efficiency.

Key developments in the testing process include:

- **AI-Based Testing Tools:** Artificial Intelligence and Machine Learning will play a significant role in detecting vulnerabilities. These technologies can analyze large volumes of data and identify potential security flaws faster than traditional testing methods.
- **Expansion to IoT and Mobile Applications:** With the rapid adoption of IoT devices and mobile applications, testing will extend beyond traditional web platforms. Ensuring secure communication between devices and applications will become essential.
- **Security for Blockchain Systems:** As blockchain technologies and digital currencies gain popularity, security testing will focus on validating the reliability and protection of blockchain-based applications and smart contracts.
- **Serverless Architecture Testing:** The growth of serverless computing will require testers to evaluate the security of cloud functions, APIs, and event-driven architectures.
- **Container and Cloud Security Testing:** Technologies such as Docker and Kubernetes are widely used for application deployment. Testing will increasingly focus on container security, configuration validation, and protection of cloud environments.

Stage 3: Future Scope of Zero Trust

The implementation of ZPA creates a strong foundation for building a modern and adaptive security framework. As organizations increasingly adopt Zero Trust strategies, several enhancements can be introduced to further strengthen security, improve operational efficiency, and support evolving digital infrastructures.

- **Integration with Zscaler Internet Access (ZIA):**
  Integrating ZPA with ZIA can create a more unified security environment where both internal applications and internet traffic are managed through a single cloud-based security platform. This integration simplifies policy enforcement and improves visibility across all user activities.
- **Advanced Device Posture Checking:**
  Future Zero Trust systems will continuously verify the security condition of user devices before granting application access. This may include checking operating system updates, antivirus status, encryption settings, and overall device health to prevent compromised devices from accessing sensitive systems.
- **Privileged Remote Access:**
  Organizations can extend ZPA capabilities to securely manage access for

external partners, contractors, and vendors. Instead of exposing internal networks, temporary and controlled access can be granted to specific applications, ensuring better protection of critical resources.

- **IoT/OT Segmentation:**
  As Internet of Things (IoT) and Operational Technology (OT) devices become more common in enterprise environments, Zero Trust models can be applied to isolate these devices. This ensures that IoT devices communicate only with authorized systems and reduces the risk of network-wide attacks.
- **AI-Driven Anomaly Detection:**
  Artificial intelligence can be used to analyze user behavior and network activity to detect unusual patterns. If suspicious activity is detected, the system can trigger alerts, enforce additional authentication steps, or temporarily block access to prevent security incidents.
- **Cloud Workload Protection:**
  With the increasing adoption of cloud platforms, Zero Trust solutions can be used to secure communication between cloud-based applications and services. This ensures that workloads running across different cloud environments remain protected from unauthorized access.
- **Automated Provisioning/Deprovisioning:**
  Identity management systems can automatically assign or remove access permissions based on changes in employee roles or status. This helps organizations maintain proper access control and reduces the risk of unauthorized access when employees leave or change departments.
- **Digital Experience Monitoring (DEM):**
  DEM tools can monitor application performance and user connectivity in real time. This helps IT teams quickly identify issues such as network delays, application downtime, or access problems, allowing them to resolve issues before they impact user productivity.

Topics Explored:

1. Zscaler
2. Zero trust
3. ZPA
4. VPN
5. MISP
6. College Network Information

7. Deployment of SOC in the College

8. Threat Intelligence

9. Incident Response

Tools Explored:

- Nessus Scanner